

Security+ 5.4 · Compliance

Mestre CyberSec · Aula 5.4 — Compliance (8:06) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Compliance: seguir a LEI + NORMA (PCI-DSS, HIPAA, GDPR, SOX/LGPD) do setor e região; reputational damage (perde cliente mesmo sem multa); monitoring (verificar, NÃO só na auditoria anual).

💡 Highlights que a prova CompTIA cobra

- Compliance: leis do setor + região (GDPR/PCI/HIPAA)
- Reputational damage costuma custar MAIS que a multa

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'protecting cardholder data'=PCI-DSS compliance

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Conformidade

Aderência a leis, regulamentos, normas e obrigações contratuais aplicáveis ao setor e à região da organização.

⚠ **Armadilha CompTIA:** Na prova, compliance não é opcional: leis do setor/região definem requisitos; multas e dano reputacional são consequências.

• Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)

Padrão de segurança para organizações que armazenam, processam ou transmitem dados de cartão de crédito, exigindo controles para proteger dados do titular do cartão.

⚠ **Armadilha CompTIA:** Se a questão mencionar 'protecting cardholder data' ou 'credit card data', a resposta é PCI-DSS.

• Lei de Portabilidade e Responsabilidade de Seguros de Saúde (HIPAA)

Lei dos EUA que protege a privacidade e a segurança de informações de saúde protegidas (PHI) mantidas por entidades cobertas e associadas de negócios.

⚠ **Armadilha CompTIA:** Gatilho: PHI, health data, medical records, healthcare providers/insurers → HIPAA.

• Regulamento Geral de Proteção de Dados (GDPR)

Regulamento da União Europeia que rege a coleta, o processamento e a transferência de dados pessoais de residentes da UE, com fortes direitos de privacidade e notificação de violações.

⚠ **Armadilha CompTIA:** Gatilho: EU residents, personal data, data subject rights, 72-hour breach notification → GDPR.

• Lei Sarbanes-Oxley (SOX)

Lei dos EUA que exige que empresas de capital aberto mantenham registros financeiros precisos e controles internos para prevenir fraudes.

⚠ **Armadilha CompTIA:** Gatilho: financial reporting, internal controls, public companies, accounting fraud → SOX.

• Lei Geral de Proteção de Dados (LGPD)

Lei brasileira de proteção de dados que regula o tratamento de dados pessoais e concede direitos aos titulares, semelhante em intenção à GDPR.

⚠ **Armadilha CompTIA:** Gatilho: Brazil, personal data, data subject rights → LGPD; não confunda com GDPR (UE).

• Dano Reputacional

Dano à marca e à confiança dos clientes causado por falha de segurança ou conformidade; frequentemente custa mais que multas regulatórias.

⚠ **Armadilha CompTIA:** A prova pode destacar que a perda de reputação e clientes pode ser mais cara que a multa; não subestime impacto não financeiro.

• Monitoramento de Conformidade

Revisão contínua ou periódica de controles, logs e processos para verificar a adesão contínua a leis, regulamentos e normas, não apenas durante auditorias anuais.

⚠ **Armadilha CompTIA:** Gatilho: 'verificar, NÃO só na auditoria anual' → monitoramento contínuo de conformidade.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma rede hospitalar nos Estados Unidos armazena e transmite informações de saúde eletrônicas protegidas em seus sistemas de faturamento, agendamento e clínicos. A equipe de conformidade está mapeando as obrigações legais e regulatórias da organização antes de uma auditoria externa. Qual framework governa mais diretamente a privacidade e a segurança desses dados de pacientes?

- A)** Payment Card Industry Data Security Standard (PCI-DSS)
- B)** Sarbanes-Oxley Act (SOX)
- C)** Health Insurance Portability and Accountability Act (HIPAA)
- D)** General Data Protection Regulation (GDPR)

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa de software sediada nos Estados Unidos oferece um serviço online para clientes localizados na União Europeia. O serviço coleta nomes, endereços de email e dados de uso. O jurídico quer garantir que a empresa cumpra suas obrigações de proteção de dados para esses usuários da UE. Qual regulamento se aplica mais diretamente?

- A)** Health Insurance Portability and Accountability Act (HIPAA)
- B)** General Data Protection Regulation (GDPR)
- C)** Payment Card Industry Data Security Standard (PCI-DSS)
- D)** Sarbanes-Oxley Act (SOX)

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa brasileira de comércio eletrônico coleta dados pessoais de clientes residentes no Brasil, incluindo nomes, endereços e históricos de navegação. O escritório de privacidade deve alinhar suas práticas de tratamento de dados com a lei nacional de proteção de dados. Qual lei se aplica mais diretamente?

- A)** Lei Geral de Proteção de Dados (LGPD)
- B)** General Data Protection Regulation (GDPR)
- C)** Sarbanes-Oxley Act (SOX)
- D)** Payment Card Industry Data Security Standard (PCI-DSS)

QUESTÃO 4 · CENÁRIO DE EXAME

Uma rede nacional de varejo aceita pagamentos com cartões de crédito e débito em milhares de lojas e por meio de seu site. A equipe de segurança está definindo controles para sistemas que armazenam, processam e transmitem dados de titulares de cartão. Qual padrão se aplica mais diretamente a esse esforço de conformidade?

- A)** Health Insurance Portability and Accountability Act (HIPAA)
- B)** General Data Protection Regulation (GDPR)
- C)** Sarbanes-Oxley Act (SOX)
- D)** Payment Card Industry Data Security Standard (PCI-DSS)

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa manufatureira de capital aberto nos Estados Unidos precisa fortalecer controles de TI que apoiam relatórios financeiros precisos e evitam alterações não autorizadas em sistemas financeiros. Auditores externos estão avaliando se a empresa cumpre suas obrigações de controles internos sobre relatórios financeiros. Qual regulamentação impulsiona mais diretamente esse requisito?

- A)** Payment Card Industry Data Security Standard (PCI-DSS)
- B)** Sarbanes-Oxley Act (SOX)
- C)** Health Insurance Portability and Accountability Act (HIPAA)
- D)** Lei Geral de Proteção de Dados (LGPD)

QUESTÃO 6 · CENÁRIO DE EXAME

Após uma violação de segurança, uma empresa evita uma multa regulatória porque a jurisdição afetada não impõe penalidade monetária para esse incidente. No entanto, a cobertura da imprensa faz clientes encerrarem contas e dois parceiros empresariais suspenderem contratos devido à perda de confiança. Qual risco relacionado à conformidade a empresa está enfrentando?

- A)** Penalidade estatutária
- B)** Violação de retenção de dados
- C)** Dano reputacional
- D)** Aumento descontrolado de escopo

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros atualmente verifica controles regulatórios apenas durante sua auditoria anual. Após a auditoria, a gestão descobre que vários servidores ficaram sem a criptografia exigida por meses, mas ninguém percebeu até a auditoria. O CISO quer visibilidade mais precoce das falhas de controle entre auditorias. Qual ação aborda melhor essa lacuna?

- A)** Implementar monitoramento contínuo de conformidade com verificações automatizadas e alertas
- B)** Agendar a próxima auditoria anual mais cedo que o normal
- C)** Exigir que os departamentos enviem formulários anuais de auto-atestação
- D)** Mover todas as cargas de trabalho regulamentadas para outro provedor de nuvem

QUESTÃO 8 · CENÁRIO DE EXAME

Uma varejista online quer reduzir o número de sistemas internos que lidam com dados de titulares de cartão. Ela planeja usar a página de checkout hospedada de um provedor de pagamentos terceirizado, para que os clientes insiram os dados do cartão diretamente na página do provedor. Antes de confiar nisso para reduzir o escopo do PCI-DSS, o que a equipe de segurança deve verificar?

- A)** A opinião de auditoria Sarbanes-Oxley do provedor para relatórios financeiros
- B)** O acordo de associado de negócios HIPAA do provedor para registros de saúde
- C)** O certificado ISO 27001 do provedor sem detalhes do escopo PCI
- D)** A atestação de conformidade PCI-DSS do provedor e os detalhes de responsabilidade compartilhada

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa que opera na UE recebe uma solicitação verificada de um cliente para apagar seus dados pessoais. Alguns registros de pedidos estão sujeitos a uma lei tributária que exige retenção por vários anos. O que a equipe de privacidade deve fazer para cumprir o GDPR enquanto lida com a obrigação legal de retenção?

- A)** Excluir todos os registros do cliente imediatamente, incluindo os dados de pedidos exigidos por lei tributária
- B)** Apagar dados não exigidos legalmente, reter apenas os registros exigidos por lei tributária e documentar a exceção
- C)** Recusar toda a solicitação porque existe algum registro tributário
- D)** Transferir a solicitação para a equipe de marketing decidir sobre a retenção

QUESTÃO 10 · CENÁRIO DE EXAME

Um hospital nos Estados Unidos descobre que um atacante acessou ePHI não criptografada de 2.000 pacientes. A equipe de resposta a incidentes confirma alta probabilidade de comprometimento. De acordo com os requisitos de notificação de violação da HIPAA, o que o responsável pela conformidade deve garantir que seja feito?

- A)** Notificar apenas o PCI Security Standards Council porque dados de cartão podem estar envolvidos
- B)** Esperar até a próxima auditoria anual e incluir o incidente no relatório de auditoria
- C)** Notificar indivíduos afetados, o Department of Health and Human Services e a mídia conforme exigido pela regra de violação
- D)** Notificar a Securities and Exchange Commission porque dados de pacientes são informações financeiras

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Health Insurance Portability and Accountability Act (HIPAA)

HIPAA é a resposta correta porque estabelece padrões nacionais nos EUA para proteger informações de saúde eletrônicas protegidas e se aplica a entidades cobertas, como hospitais e seus associados de negócios. PCI-DSS se aplica a dados de cartões de pagamento, SOX se aplica a controles de relatórios financeiros de empresas de capital aberto, e GDPR se aplica a dados pessoais de indivíduos na União Europeia.

Questão 2: Alternativa B — General Data Protection Regulation (GDPR)

GDPR é a resposta correta porque se aplica ao tratamento de dados pessoais de titulares na União Europeia, independentemente de onde a empresa está sediada, ao oferecer bens ou serviços ou monitorar comportamento. HIPAA cobre dados de saúde nos EUA, PCI-DSS cobre dados de cartões e SOX cobre controles de relatórios financeiros.

Questão 3: Alternativa A — Lei Geral de Proteção de Dados (LGPD)

LGPD é a resposta correta porque é a lei geral brasileira de proteção de dados que rege o tratamento de dados pessoais de indivíduos no Brasil. GDPR é o regulamento de proteção de dados da UE, SOX trata de controles de relatórios financeiros e PCI-DSS trata da segurança de dados de cartões de pagamento.

Questão 4: Alternativa D — Payment Card Industry Data Security Standard (PCI-DSS)

PCI-DSS é a resposta correta porque é o padrão do setor para organizações que armazenam, processam ou transmitem dados de titulares de cartão. HIPAA se aplica a informações de saúde, GDPR se aplica à privacidade de dados pessoais na UE, e SOX se aplica a controles de relatórios financeiros de empresas de capital aberto.

Questão 5: Alternativa B — Sarbanes-Oxley Act (SOX)

SOX é a resposta correta porque exige que empresas de capital aberto nos EUA mantenham controles internos sobre relatórios financeiros, incluindo controles gerais de TI que afetam sistemas financeiros. PCI-DSS está relacionado a dados de cartões, HIPAA a informações de saúde, e LGPD à lei brasileira de proteção de dados.

Questão 6: Alternativa C — Dano reputacional

Dano reputacional é a resposta correta porque a empresa está perdendo clientes e parceiros devido à perda de confiança, mesmo sem multa monetária. Penalidade estatutária é uma multa legal, violação de retenção de dados envolve manter dados por mais tempo que o permitido, e aumento descontrolado de escopo refere-se à expansão não controlada dos requisitos do projeto.

Questão 7: Alternativa A — Implementar monitoramento contínuo de conformidade com verificações automatizadas e alertas

Monitoramento contínuo de conformidade é a resposta correta porque usa verificações automatizadas, painéis e alertas para detectar falhas de controle entre auditorias. Auditar mais cedo ainda é pontual, auto-atestação anual é pouco frequente, e mover cargas de trabalho para outro provedor de nuvem não fornece, por si só, visibilidade contínua de conformidade.

Questão 8: Alternativa D — A atestação de conformidade PCI-DSS do provedor e os detalhes de responsabilidade compartilhada

A equipe de segurança deve verificar a atestação de conformidade PCI-DSS do provedor e as responsabilidades compartilhadas claramente definidas. Usar um provedor validado e campos hospedados pode reduzir o escopo do PCI-DSS, mas SOX, HIPAA ou um certificado ISO 27001 genérico sozinho não estabelece conformidade PCI-DSS para dados de titulares de cartão.

Questão 9: Alternativa B — Apagar dados não exigidos legalmente, reter apenas os registros exigidos por lei tributária e documentar a exceção

A equipe de privacidade deve apagar dados que não são exigidos legalmente, reter apenas os registros sujeitos à retenção tributária e documentar a exceção legal. Os direitos de eliminação do GDPR não são absolutos quando a retenção é exigida por lei. Excluir registros tributários viola a lei, recusar toda a solicitação é excessivo, e marketing não é o tomador de decisão apropriado.

Questão 10: Alternativa C — Notificar indivíduos afetados, o Department of Health and Human Services e a mídia conforme exigido pela regra de violação

A HIPAA exige que entidades cobertas notifiquem os indivíduos afetados, o Department of Health and Human Services e, em alguns casos, a mídia, sem atraso indevido e geralmente dentro de 60 dias. Notificar o PCI Council é incorreto porque se trata de dados de saúde, não de cartão. Esperar por uma auditoria anual é não conforme, e a SEC não é o destinatário apropriado para uma violação de HIPAA.